

DTS Permissions Matrix by Role

Roles

superadmin, officer, non_officer, fcos, office_station

1. Public (no login - all users)

Track document by tracking number, view document QR code

1. L
2. o
3. g
4. i
5. n
- 6.
7. (
8. p
9. a
10. s
11. s
12. w
13. o
14. r
15. d
- 16.
17. &
- 18.
19. p
20. i
21. n
22. c
23. o
24. d
25. e
26.)
27. ,
- 28.
29. 2
30. F

- 31. A
- 32.
- 33. v
- 34. e
- 35. r
- 36. i
- 37. f
- 38. y
- 39. ,
- 40.
- 41. f
- 42. o
- 43. r
- 44. g
- 45. o
- 46. t
- 47. /
- 48. r
- 49. e
- 50. s
- 51. e
- 52. t
- 53.
- 54. p
- 55. a
- 56. s
- 57. s
- 58. w
- 59. o
- 60. r
- 61. d

2. Any logged-in user (ALL 5 roles)

Guarded only by auth:sanctum (routes/api.php:26-292)

3. Superadmin only (admin middleware - api.php:300, 306, 612)

1. Users admin: list with account numbers, create account, provision from personnel, edit, delete (cannot delete superadmin)
2. Personnel: transfer between offices, clear all non-superadmin records
3. Settings: view/update default SLA hours
4. Suggestions: respond/delete
5. Database: info, backup (pg_dump), optimize (VACUUM ANALYZE), download backups
6. Activity log (audit trail)
7. Frontend only: sees Administration menu; /personnel and /admin/activity guarded via AdminRoute (App.tsx:49)

Findings / gaps

1. canApprove() (SUPERADMIN/OFFICER/FCOS) exists in User.php:113 but is never called - document routing/approval has no actual role gating.
2. /admin/users, /admin/templates, /admin/offices pages are not wrapped in AdminRoute on the frontend (App.tsx:108-110) - only menu-hidden. Non-superadmins could reach them by URL, and the offices/personnel/templates APIs behind them are not admin-gated.
3. Personnel create/import/export and office CRUD are effectively open to all authenticated roles.